

Security Monitoring Architecture: LLDAP + OpenFGA + libcloud REST + Vault

Overview

Every component in the stack emits logs, metrics, or audit events that carry security-relevant signal. This document maps each log source to its fields, then organises the monitoring capabilities built on top of them – covering real-time threat detection, forensic analysis, incident reporting, and compliance. The architecture converges all sources into a centralised observability pipeline feeding a SIEM.

Part 1 — Log Sources and What Each Emits

1.1 LLDAP / Active Directory (Identity Layer)

LLDAP exposes structured application logs; AD/OpenLDAP emit LDAP access and audit logs that should be enabled explicitly.^{[1][2]}

Key events and fields:

Event	Relevant Fields	Security Value
Bind (authentication)	timestamp, bindDN, client_ip, port, result (success/fail)	Detect brute-force, credential stuffing, off-hours login
Search query	bindDN, base, filter, attributes, result_count	Detect directory harvesting (e.g., enumerating all users/groups)
Group membership change	actor, target_user, group, operation (add/remove)	Detect unauthorised privilege escalation
User create / delete	actor, new_user, timestamp	Track account lifecycle; detect rogue account creation
Admin credential bind	bindDN=admin, client_ip	Admin binds from unexpected IPs are a critical alert
Failed bind (repeated)	bindDN, client_ip, error_code	Brute-force indicator

Enabling in OpenLDAP: add overlay `auditlog` in `slapd.conf`.^[^2]

Enabling in Active Directory: enable *DS Access*, *Account Logon*, and *Account Management* audit categories via Group Policy Management Console (GPMC).^[^2]

1.2 Vault (Secrets & Auth Layer)

Vault's audit device is its most forensically rich log source. Crucially, **Vault will not respond to client requests it cannot log** — meaning audit logging is blocking by design, not advisory. Every request and response is recorded in structured JSON.^{[3][4][5]}

Key fields in a Vault audit entry:^{[6][4]}

```
{
  "time": "2026-07-03T09:00:00Z",
  "type": "request",
  "auth": {
    "client_token": "<hmac>",
    "display_name": "ldap-alice",
    "policies": ["cloud-admin-aws"],
    "token_type": "service",
    "accessor": "abc123"
  },
  "request": {
    "id": "req-uuid",
    "operation": "read",
    "path": "aws/creds/ec2-admin",
    "remote_address": "10.0.1.5",
    "namespace": "root"
  },
  "response": {
    "secret": { "lease_id": "aws/creds/ec2-admin/xyz", "lease_duration": 3600 }
  }
}
```

Critical events to monitor:^{[7][5]}

Event	request.path pattern	Security Value
Root token creation	sys/generate-root	Highest-severity alert — should almost never occur
Root token usage	auth.display_name = "root"	Critical — root access is unrestricted
Audit device modification	sys/audit	Attacker silencing audit trail
Policy modification	sys/policies/acl/*	Privilege escalation via policy change
Secrets engine enable/disable	sys/mounts/*	Infrastructure change; should match change tickets
Dynamic credential request	<engine>/creds/<role>	Who requested a cloud credential and from which IP
Auth failure spike	response.auth = null + response.errors	Credential stuffing or token theft
Lease revocation	sys/leases/revoke*	Incident response action; unexpected revocation is suspicious

Event	request.path pattern	Security Value
LDAP group/user lookup (Vault auth)	auth/ldap/login/*	Tracks which LDAP users authenticated to Vault

Best practices:[^5]

- Enable two audit devices — file (local) + syslog/socket (remote). Vault blocks all requests if the only audit device is unavailable.
- Use a dedicated disk partition for file audit device.
- Set `hmac_accessor = false` to preserve token accessors for revocation without exposing secrets.[^5]
- Set `elide_list_responses = true` to reduce log volume from list operations.

1.3 OpenFGA (Authorization Layer)

OpenFGA emits structured JSON logs for every API call and supports OpenTelemetry metrics and distributed tracing.[^8][9]

Structured log fields (per request):[^10][8]

Field	Value
store_id	The FGA store
authorization_model_id	Which model version was used
method	Check, Write, Read, ListObjects, ListUsers
user	Subject of the check (e.g. user:alice)
object	Resource being checked (e.g. api:compute.provision)
relation	The permission being evaluated
allowed	true / false
latency_ms	Resolution time
client_ip	Originating caller
error	If present, indicates model or store error

OpenTelemetry metrics emitted by the OpenFGA SDK include:[^9][11]

- `fga-client.request.duration` — histogram of total request time
- `fga-client.query.duration` — server-side evaluation time
- `fga-client.credentials.request` — counter for credential refreshes
- `http.response.status_code` — HTTP status distribution (403 rate is key)
- `fga-client.user` — the user subject (disabled by default due to cardinality; enable for security monitoring)[^11]

Key alert conditions:

- Spike in `allowed = false` for a single user → potential privilege probe
- `allowed = false` followed immediately by `allowed = true` for same user/object → tuple was written mid-session (possible privilege escalation)
- `method = Write` or `method = Delete` on tuples outside of reconciler process → rogue tuple manipulation
- `authorization_model_id` mismatch with expected pinned ID in libcloud REST config → model tampering or config drift

1.4 libcloud REST API (Application Layer)

libcloud REST is the system that sits between users and cloud providers. It must emit structured access logs as the **correlation anchor** — it holds the full request context that neither OpenFGA nor Vault see alone.

Recommended log fields to emit per request:

Field	Purpose
<code>request_id</code> (UUID, propagated)	Correlate across Vault, OpenFGA, and cloud provider logs
<code>user</code>	Authenticated username from LDAP/OIDC token
<code>source_ip</code>	Client IP
<code>http_method+path</code>	The REST endpoint called
<code>provider</code>	Cloud provider targeted
<code>vault_lease_id</code>	Which credential was used (links to Vault audit)
<code>fga_check_result</code>	The OpenFGA allow/deny decision
<code>cloud_request_id</code>	Cloud provider's own correlation ID (AWS RequestID, etc.)
<code>duration_ms</code>	End-to-end latency
<code>status_code</code>	HTTP response status
<code>error</code>	Any error detail

The `request_id` must be propagated as a trace header (X-Request-ID or OpenTelemetry traceparent) through to both the OpenFGA check call and the Vault credential fetch so that all three log entries can be joined in the SIEM.

1.5 Cloud Provider Native Logs

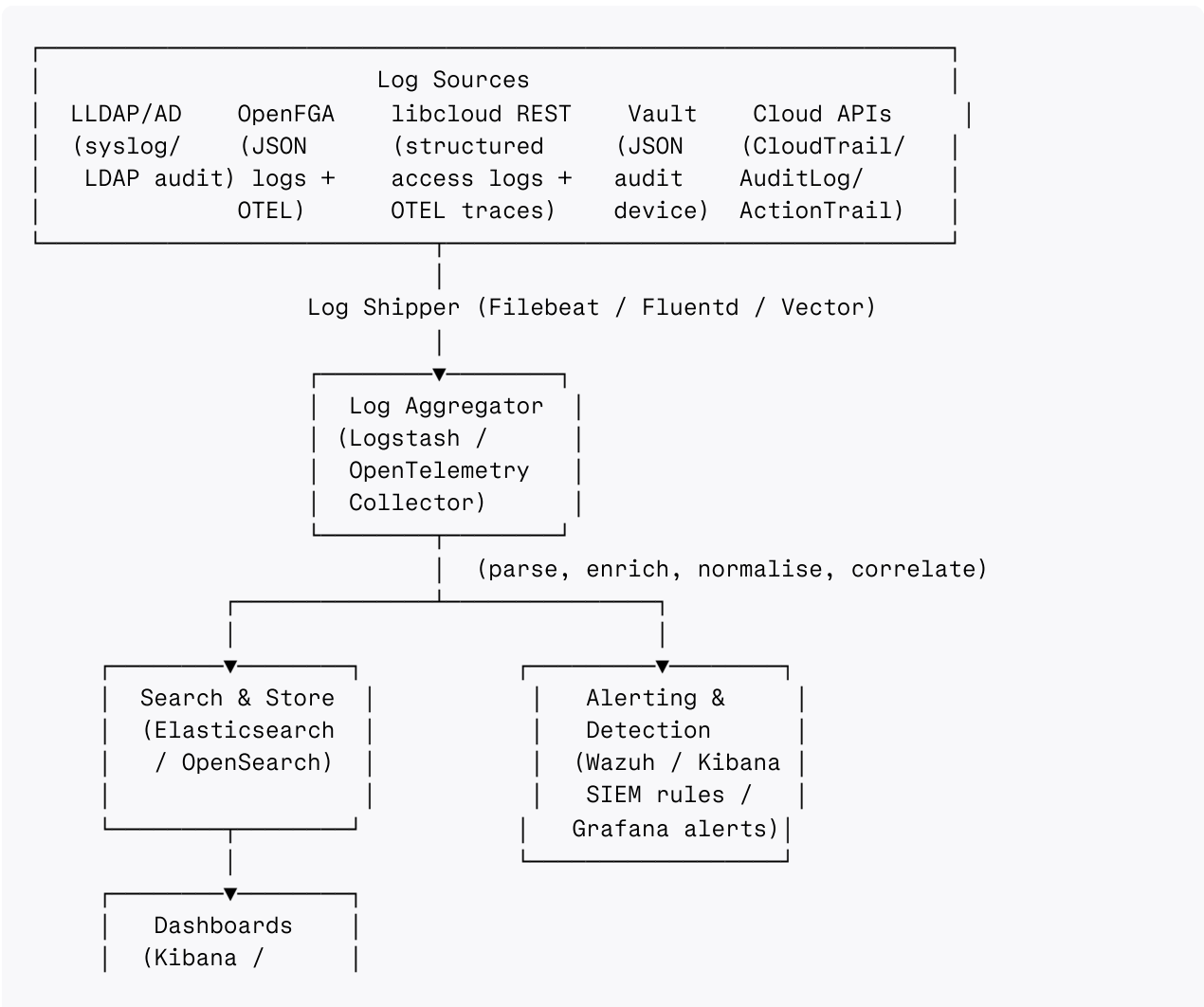
These are out-of-band from the stack but essential for forensics — they record what actually happened at the cloud API level, independent of whether libcloud REST is compromised.

Provider	Log Source	Key Events
AWS	CloudTrail	Every API call: caller ARN, source IP, event name, resource
GCP	Cloud Audit Logs	Admin Activity, Data Access, System Event logs
Azure	Activity Log + Entra Sign-in logs	ARM operations, identity events
Alibaba	ActionTrail	API operations with caller identity and IP
Nutanix (Prism)	Audit Log API	VM create/delete, config changes, user actions

Cloud provider logs are the **last line of forensic truth** — if credentials leaked and were used outside of libcloud REST, these logs will show access that has no corresponding entry in the libcloud REST logs.

Part 2 — Observability Pipeline Architecture

All log sources should feed into a single centralised pipeline:



Recommended open-source stack: Wazuh as the SIEM engine (integrates natively with Elasticsearch/OpenSearch, provides pre-built detection rules, MITRE ATT&CK mapping, file integrity monitoring, and compliance dashboards) combined with **OpenTelemetry Collector** to normalise OTEL signals from OpenFGA and libcloud REST.^{[12][13][14][15]}

Part 3 — Correlation Rules and Detection Use Cases

Correlation rules join events from multiple sources to detect attacks that no single log source can see alone. The `request_id` / `traceparent` propagation from libcloud REST is the join key.

3.1 Credential and Identity Attacks

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
Brute-force LDAP bind	LLDAP/AD	>5 failed bind attempts for same <code>bindDN</code> within 60s from same IP	T1110 (Brute Force)
Directory enumeration	LLDAP/AD	LDAP search with broad filter <code>((objectClass=*))</code> returning >100 results from a non-service account	T1087.002 (Domain Account Discovery)
Rogue LDAP group add	LLDAP/AD	Group membership write by account that is not in the <code>cloud-owner</code> group	T1098 (Account Manipulation)
Vault auth anomaly	Vault	Successful <code>auth/ldap/login</code> from a new IP not seen for this user in last 30 days	T1078 (Valid Accounts)
Vault root token use	Vault	Any <code>auth.display_name = "root"</code> in audit log	T1078.004 (Cloud Accounts)
Vault policy modification	Vault	Write to <code>sys/policies/acl/*</code> outside of change window	T1484 (Domain Policy Modification)
Vault audit device tampered	Vault	Write/delete to <code>sys/audit/*</code>	T1562.008 (Disable Cloud Logs)

3.2 Authorization Bypass Attempts

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
OpenFGA permission probe	OpenFGA	>10 <code>allowed=false</code> Check calls from same user within 60s across different objects	T1069 (Permission Groups Discovery)
Tuple injection attempt	OpenFGA	Write API call to OpenFGA originating from an IP that is NOT the reconciler service IP	T1098 (Account Manipulation)
Authorization model swap	OpenFGA + libcloud REST	<code>authorization_model_id</code> in OpenFGA response differs from the pinned model ID configured in libcloud REST	T1484

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
FGA deny followed by libcloud success	OpenFGA + libcloud REST	Same <code>request_id</code> appears as <code>allowed=false</code> in OpenFGA but results in a 200 from libcloud REST	Authorization bypass — highest severity

3.3 Secrets Exfiltration

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
Credential harvest	Vault	>3 <code>read</code> operations on <code><engine>/creds/*</code> within 60s by same token	T1552 (Unsecured Credentials)
Credential used outside libcloud REST	Vault + Cloud Provider	<code>vault_lease_id</code> from Vault audit log does not appear in any libcloud REST access log, but cloud provider log shows API call with that credential	T1550 (Use Alternate Auth Material)
Unexpected cloud region access	Cloud Provider + libcloud REST	Cloud provider log shows API call in region not present in any libcloud REST request for same credential	T1535 (Unused/Unsupported Cloud Regions)
Vault credential requested then immediately exported	Vault + network	Outbound network connection to external IP within 30s of a Vault <code>read</code> on <code>creds</code> path	T1041 (Exfiltration Over C2 Channel)
Short-lived credential reuse after expiry	Vault + Cloud Provider	Cloud provider API call timestamp is after <code>lease_duration</code> of the corresponding Vault lease	Stolen credential reuse

3.4 Privilege Escalation

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
LLDAP group add then Vault policy elevation	LLDAP + Vault	Within 10 minutes: LLDAP group membership add event → new Vault token with elevated policies for same username	T1078 + T1098
Self-role-assignment	LLDAP + OpenFGA	<code>lldap-group-add-member</code> called where <code>actor == target_user</code>	T1098.001
Break-glass abuse	OpenFGA + libcloud REST	Break-glass tuple grant followed by destructive operation (DELETE node, DROP bucket) rather than read/diagnose	T1078
Vault role creation	Vault	New role written to <code><engine>/roles/*</code> by token that is not in <code>cloud-owner</code> policy	T1548 (Abuse Elevation Control Mechanism)

3.5 Operational Integrity / Insider Threat

Detection Name	Log Sources	Correlation Logic	MITRE ATT&CK
Mass node destruction	libcloud REST + Cloud Provider	>3 destroy operations by same user within 5 minutes	T1485 (Data Destruction)
Offboarding bypass	LLDAP + OpenFGA + Vault	User account disabled in LLDAP but OpenFGA tuples still exist OR Vault tokens still valid 30 min after offboarding	T1078 (Valid Accounts)
After-hours admin activity	libcloud REST + LLDAP	Admin-role operations performed outside of defined business hours (configurable per org)	Insider threat indicator
Script execution from unexpected host	libcloud REST	source_ip for admin script calls appears from a new host not in the known admin workstation list	T1078

Part 4 — Forensic Analysis Capabilities

For post-breach investigation, the combination of logs enables a complete reconstruction of attacker progression.

Forensic Query Patterns

1. Reconstruct all actions of a compromised user across all systems:

```
# Step 1: Find all LDAP binds by user
grep '"bindDN":"uid=alice"' /var/log/slapd-audit.log

# Step 2: Find all Vault authentications by that user
jq 'select(.auth.display_name == "ldap-alice")' vault_audit.log

# Step 3: Find all Vault credentials requested under those tokens
jq 'select(.auth.display_name == "ldap-alice" and .request.operation == "read")' vault_audit.log

# Step 4: Find all OpenFGA checks for that user
grep '"user":"user:alice"' openfga_access.log

# Step 5: Find all libcloud REST calls by that user
jq 'select(.user == "alice")' libcloud_access.log

# Step 6: Cross-check cloud provider logs for any use of alice's credentials
aws cloudtrail lookup-events --lookup-attributes AttributeKey=Username,AttributeValue=alice
```

2. Revoke all live credentials from a compromised IP immediately:[^16]

```
# From Vault audit log, extract all lease IDs originating from compromised IP
for LEASE in $(jq -r 'select(.request.remote_address == "10.1.2.3") | .response.secret_id' vault_audit.log); do
  vault lease revoke "$LEASE"
done
```

3. Determine blast radius of a stolen Vault token:

```
# Find all paths accessed by the HMAC of a known token
HMAC=$(vault write sys/audit-hash/file-audit input "<raw_token>" | jq -r .data.hash)
jq --arg h "$HMAC" 'select(.auth.client_token == $h)' vault_audit.log
```

4. Find the first appearance of a new credential in cloud provider logs (zero-day detection):

```
# AWS: Find calls made with a dynamically generated access key before it appeared in
aws cloudtrail lookup-events --lookup-attributes AttributeKey=AccessKeyId,AttributeV
```

Log Retention Requirements for Forensics

Log Source	Minimum Retention	Recommended Retention	Reason
Vault audit	1 year	3 years	Credential lifecycle; breach attribution
LLDAP/AD audit	1 year	3 years	Identity change history
OpenFGA access logs	90 days	1 year	Permission decision trail
libcloud REST access logs	1 year	3 years	The correlation anchor for all other logs
Cloud provider (CloudTrail etc.)	90 days (default)	1 year+ (archive to S3/GCS)	Ground truth for what actually executed
SIEM correlation events	1 year	3 years	Incident timelines

Part 5 — Incident Reporting Artifacts

For each security incident, the monitoring stack should produce the following artifacts automatically:

Artifact	Source	Content
Timeline report	SIEM (Wazuh / Kibana)	Chronological list of all events from first anomaly to containment, with <code>request_id</code> join across systems
User activity dossier	LLDAP + Vault + FGA + libcloud REST	Every action performed by the affected user/credential across all systems in the incident window
Credential blast radius report	Vault + Cloud Provider	All lease IDs issued, which cloud resources were touched, and whether any external access was detected
Authorisation decision log	OpenFGA	All Check calls in the incident window: what was allowed, what was denied, and any anomalous tuple writes
Remediation verification report	All sources	Post-containment confirmation that: LDAP account disabled, OpenFGA tuples deleted, Vault leases revoked, cloud provider credentials deactivated

Part 6 — Recommended Tooling Stack

Layer	Open-Source Option	Commercial Option	Purpose
Log shipper	Filebeat / Vector / Fluentd	Cribl	Collect and forward all log sources
OTEL collector	OpenTelemetry Collector	AWS Distro for OTEL	Normalise metrics/traces from OpenFGA and libcloud REST
Log storage + search	OpenSearch / Elasticsearch	Splunk / Datadog	Store, index, and query all logs
SIEM + detection	Wazuh (SIEM + XDR, free)	IBM QRadar / Microsoft Sentinel	Correlation rules, alerts, MITRE ATT&CK mapping, compliance dashboards ^{[12][13]}
Metrics / dashboards	Grafana + Prometheus	Datadog	Real-time dashboards for FGA denial rates, Vault auth failures, libcloud error rates ^[17]
Distributed tracing	Jaeger / Tempo	Datadog APM	End-to-end trace via <code>traceparent</code> from libcloud REST → OpenFGA → Vault ^[9]
Alerting	Alertmanager / Grafana alerts	PagerDuty	Route alerts to on-call based on severity
Log analysis (ad-hoc)	jq + shell scripts	—	Rapid forensic queries against Vault audit log during incident ^{[18][7]}

Wazuh is the recommended SIEM for this stack given its open-source licensing, native support for syslog ingestion (compatible with Vault's syslog audit device and LDAP audit logs), built-in MITRE ATT&CK rule mapping, file integrity monitoring for script files, and compliance dashboards for PCI-DSS, NIST 800-53, and ISO 27001.^{[14][19][^12]}

Part 7 — MITRE ATT&CK Coverage Map

The detections above collectively cover the following ATT&CK tactics as they apply to this architecture:^{[20][21][^22]}

Tactic	Relevant Techniques	Covered By
Initial Access	T1078 Valid Accounts	Vault auth anomaly, LDAP bind monitoring
Persistence	T1098 Account Manipulation	LDAP group change alerts, FGA tuple write monitoring
Privilege Escalation	T1548, T1078.004	Vault policy modification, self-role-assignment detection
Defense Evasion	T1562.008 Disable Cloud Logs	Vault audit device tamper alert
Credential Access	T1552 Unsecured Credentials, T1550	Credential harvest detection, external credential use detection
Discovery	T1087.002, T1069	LDAP enumeration, FGA permission probe
Lateral Movement	T1021.007 Cloud Services	Cross-provider activity with single leaked credential
Exfiltration	T1041	Network + Vault correlation
Impact	T1485 Data Destruction, T1489	Mass destroy detection

References

1. [Server audit log settings](#) - Audit logging is used to improve the security of the directory server. A default audit plug-in is pr...
2. [Audit-Ready Access Logs for LDAP: Best Practices and Insights](#) - Audit logs are essential in ensuring that access to applications, services, and sensitive informatio...
3. [Audit Devices | Vault - HashiCorp Developer](#) - Audit devices are mountable devices that log requests and responses in Vault.
4. [Audit log entry schema | Vault - HashiCorp Developer](#) - Schema reference for Vault audit log entries.
5. [Audit logging best practices | Vault - HashiCorp Developer](#) - Recommendations for setting up audit logging in HashiCorp Vault.
6. [Sending HashiCorp Audit Logs to IBM QRadar SIEM via Syslog](#)
7. [Query audit device logs | Vault - HashiCorp Developer](#) - Learn how to query file audit device logs in an ad-hoc way during troubleshooting incidents.
8. [Configuring OpenFGA](#) - If using Pre-shared key authentication, you will configure OpenFGA with one or more secret keys and ...
9. [Supported Attributes](#) - How to configure your SDK Client to collect telemetry using OpenTelemetry.
10. [FGA Logging | Auth0 Fine-Grained Authorization \(FGA\) Docs](#) - The Logging API is designed to provide authorization activity in a standardized format for developer...
11. [js-sdk/docs/opentelemetry.md at main · openfga/js-sdk](#) - OpenFGA SDK for node.js and JavaScript - <https://www.npmjs.com/package/@openfga/sdk> - openfga/js-sdk
12. [Wazuh - Open Source XDR. Open Source SIEM.](#) - Wazuh is a free and open source security platform that unifies XDR and SIEM protection for endpoints...
13. [Wazuh SIEM: Open source security monitoring platform](#) - The Wazuh SIEM solution is a centralized platform for aggregating and analyzing telemetry in real ti...
14. [Wazuh – Open Source Security Platform for Threat Detection, Visibility & Compliance](#) - Wazuh is a free, open-source security platform for Linux, Windows, and cloud environments. Detect th...
15. [OpenTelemetry Security Audit Published](#) - Thousands of organizations and millions of users around the world rely on OpenTelemetry as part of t...
16. [vault-guides/governance/audit/README.md at master · hashicorp/vault-guides](#) - Example usage of HashiCorp Vault secrets management - hashicorp/vault-guides
17. [Secure HashiCorp Vault with Datadog Cloud SIEM](#) - Understand the common threats to HashiCorp Vault and learn how Datadog Cloud SIEM can automatically ...
18. [Vault Audit Log analysis using jq CLI - HashiCorp Support](#) - This article is a quick start guide with tips on using the Command Line Interface (CLI): jq to perfo...
19. [SIEM using Wazuh - Microsoft Marketplace](#) - Open Source Security Information and Event Management. Real-time security monitoring, log analysis, ...
20. [Matrix - Enterprise - Identity Provider - MITRE ATT&CK®](#)

21. How should security teams use MITRE ATT&CK in identity programmes? - Use ATT&CK to connect identity events to attacker behaviour, not just to label alerts. Map authentic...
22. MITRE ATTACK Framework: Tactics, Techniques, and More - Wiz - Wiz maps real-time detections to the MITRE ATT&CK Cloud Matrix, enabling teams to measure coverage g...